

Social engineering inom cybersäkerhet

Psykologiska och tekniska aspekter av digital manipulation



Max Ruotsalainen
Kandidatavhandling i datateknik
Handledare: Annamari Soini
Fakulteten för naturvetenskap och teknik
Åbo Akademi
2026

Referat

I ett växande samhälle där digitala tjänster, molnplattformar och nätverksbaserade system kontinuerligt integreras i både offentliga och privata verksamheter, ökar betydelsen av cybersäkerhet. I takt med att skyddsåtgärder utvecklas förändras hotbilden. En särskilt framträdande kategori av hot är social engineering, där hotaktörer inte direkt utnyttjar tekniska sårbarheter utan manipulerar mänskligt beteende och beslutsfattande. Avhandlingen analyserar social engineering som ett cybersäkerhetshot i moderna digitala miljöer med fokus på hur tekniska verktyg och psykologiska mekanismer samverkar för att möjliggöra framgångsrika cyberattacker.

Utvecklingen av artificiell intelligens och generativa modeller har ytterligare förändrat hotlandskapet. Deepfake-teknologi och AI-genererat innehåll skapar nya möjligheter för hotaktörer att producera mer trovärdiga och tekniskt sofistikerade bedrägerier. Även om hotbilden har ökat i komplexitet, finns det olika tekniska och organisatoriska försvarsmekanismer som kan användas för att minska risken för manipulation. Genom att förstå social engineering som ett sociotekniskt säkerhetshot, där tekniska, organisatoriska och mänskliga faktorer samverkar, kan mer effektiva skyddsåtgärder utvecklas.

Nyckelord

Innehåll

1	Inledning	1
1.1	Syfte	1
1.2	Forskningsfrågor	2
1.3	Disposition	2
2	Bakgrund och teori	3
2.1	Cybersäkerhet i moderna digitala system	3
2.2	Social Engineering som cybersäkerhetsshot	4
2.3	Psykologiska mekanismer bakom social engineering	5
2.4	Angreppsmetoder och attacktyper	5
2.4.1	Nätfiske och spjutfiske	6
2.4.2	Pretexting och identitetsbedrägeri	7
2.4.3	Insider-relaterade attacker	8
3	Social engineering i praktiken	9
3.1	Social engineering i samhällskritiska system	9
3.2	Fallstudier av social engineering-relaterade incidenter	10
3.2.1	Arup deepfake-bedrägeri	10
3.2.2	USA:s presidentval 2016	11
3.3	Konsekvenser av social engineering-attacker	12
4	Tekniska motåtgärder mot social engineering	13
4.1	Identifiering och detektion av social engineering-attacker	13
4.2	Artificiell intelligens som försvarsmekanism	14
4.2.1	Användningen av maskininlärning för detektion	15
4.2.2	Begränsningar och risker med AI	15
4.3	Autentisering och åtkomstkontroll	16
5	Diskussion	18

6 Slutsats	19
Källförteckning	20

Kapitel 1

Inledning

Traditionellt har cybersäkerhet främst fokuserat på tekniska skyddsmekanismer som brandväggar, kryptering och intrångsdetektion, men med digitaliseringens raska framsteg och förekomsten av nya angreppsmetoder har skyddet mot dessa hot blivit allt mer komplicerat [1]. Enligt [2, 3] har hotaktörer börjat i allt större grad utnyttja mänskliga faktorer snarare än enbart tekniska sårbarheter. Social engineering definieras därmed som en angreppsform där psykologisk manipulation används för att få individer att lämna ut känslig information eller utföra handlingar som äventyrar säkerheten [4]. Därför bör social engineering förstås som ett socio-tekniskt fenomen där tekniska system, organisatoriska strukturer och mänskligt beslutsfattande används för att begå brott [5].

Eftersom människan spelar en avgörande roll i social engineering-relaterade incidenter har den Europeiska unionens cybersäkerhetsbyrå (ENISA) börjat betona vikten av hur individuella beteenden, organisatoriska kulturer och arbetsprocesser påverkar förebyggandet av dessa attacker [6]. Detta innebär att enbart tekniska skyddsåtgärder inte är tillräckliga för att hantera cyberhotet. Därtill har utvecklingen av artificiell intelligens (AI) ytterligare förändrat social engineering som ett cyberhot. Generativ AI har börjat användas för att producera mer avancerade attacker, vilket i sin tur har försvårat identifiering och detektion [7]. Samtidigt har AI också blivit ett verktyg för att stärka försvarssystemen genom avancerad mönsterigenkänning och hotanalys. Detta har lett till en kontinuerlig kapprustning där både hotaktörer och organisationer strävar efter att ha försprång.

1.1 Syfte

Syftet med denna kandidatavhandling är att analysera social engineering som ett cybersäkerhetshot med ett särskilt fokus på samspelet mellan tekniska och psykologiska faktorer. Begreppet social engineering saknar en entydig svensk översättning, men används ibland som exempelvis social manipulation eller social ingenjörskonst. I denna avhand-

ling används den engelska termen, då den är etablerad inom internationell forskning och förekommer i litteraturen.

Avhandlingen ämnar att föra fram hur social engineering-attacker fungerar, varför de är effektiva och hur de kan förstås inom ramen för cybersäkerhetens socio-tekniska perspektiv. Som grund för avhandlingen används litteraturstudier där vetenskapliga artiklar, översiktsstudier och relevanta rapporter analyseras och sammanställs. Målet med avhandlingen är att bidra till en fördjupad förståelse av social engineering genom att identifiera centrala utmaningar kopplade till detektion och förebyggande av denna typ av cyberhot.

1.2 Forskningsfrågor

I avhandlingen kommer fyra forskningsfrågor att behandlas. Inledningsvis förklaras social engineering i kontexten av modern cybersäkerhet. Därefter analyseras de psykologiska och tekniska mekanismer som möjliggör social engineering som ett effektivt cyberhot. Slutligen undersöks metoder som finns för att motverka, identifiera och filtrera social engineering i praktiken. Forskningsfrågorna ser ut som följande:

1. Vilka psykologiska mekanismer bidrar till att social engineering-attacker är effektiva?
2. Vilka tekniska metoder och attacktyper används i dagens social engineering-attacker?
3. Vilka identifierings- och detektionsmetoder kan användas för att upptäcka social engineering?
4. I vilken grad kan artificiell intelligens och automatiserade system bidra till att förebygga och motverka social engineering?

1.3 Disposition

Kapitel 2

Bakgrund och teori

Detta kapitel presenterar den teoretiska bakgrund som krävs för att förstå social engineering som ett cybersäkerhetshot. Inledningsvis diskuteras cybersäkerhetens roll i moderna digitala system och grunden för att förstå cybersäkerhet i dagens digitala miljöer. Kapitlet kommer också att behandla social engineering som ett fenomen, med fokus på dess unika angreppssätt som utnyttjar mänskliga faktorer snarare än enbart tekniska sårbarheter. Avslutningsvis diskuteras de psykologiska mekanismer som ligger till grund för social engineering-attacker och en genomgång av vanliga angreppsmetoder och attacktyper.

2.1 Cybersäkerhet i moderna digitala system

Under de senaste årtiondena har digitaliseringen lett till att samhällsfunktioner, organisationer och individer blivit alltmer beroende av digitala system. Utvecklingen har möjliggjort effektivare verksamhetsprocesser och skapat ett överflöd av nya digitala tjänster. Däremot har utvecklingen också samtidigt ökat systemens exponering för cyberhot och expanderat attackytan för hotaktörer [8].

För moderna digitala system kan cybersäkerhet förstås som skyddet av digital information och system genom tekniska, organisatoriska och mänskliga åtgärder. Enligt [5, 6] ingår det i cybersäkerhet inte enbart teknik, utan också socio-tekniska fenomen där mänskliga faktorer spelar en central roll. Detta innebär att ett ensidigt fokus på tekniska sårbarheter inte är tillräckligt för att skydda moderna digitala system.

Därtill kännetecknas dagens digitala system av en hög grad av sammankoppling och komplexitet. Digitala system består av flera lager, tjänster och aktörer som samverkar i nätverksbaserade strukturer [9]. Enligt [9] innebär strukturen att sårbarheter i en del av systemet kan leda till konsekvenser i andra delar. Komplexiteten leder till försvårad riskbedömning, säkerhetsstyrning och incidenthantering.

Därpå har den ökade användningen av digital kommunikation, såsom e-post, nätba-

serade plattformar och e-tjänster, skapat nya möjligheter för angripare att nå målgrupper med begränsade resurser [10]. Även om tekniska försvarsmekanismer utvecklas kontinuerligt, anpassar angripare sina metoder i takt med förbättrad cybersäkerhet.

För att sammanfatta kännetecknas moderna digitala system av komplexitet, sammankoppling och ett beroende av mänsklig interaktion. Enligt [5, 6] kräver cybersäkerheten i dessa miljöer ett integrerat perspektiv där tekniska lösningar kombineras med förståelse för organisatoriska och mänskliga faktorer.

2.2 Social Engineering som cybersäkerhetshot

Begreppet social engineering har historiskt använts inom samhällsvetenskap för att beskriva planerade försök att forma sociala strukturer och mänskligt beteende. I modern cybersäkerhetskontext har begreppet däremot fått en mer begränsad betydelse och syftar främst på manipulation av individer i digitala miljöer [11].

Social engineering utgör en attackform där tekniska verktyg och psykologisk manipulation kombineras för att påverka individers beteende i digitala miljöer [8, 9]. Till skillnad från traditionella cyberhot, som fokuserar på rent tekniska intrång, strävar social engineering efter att få användare att frivilligt kringgå etablerade säkerhetsåtgärder. Hotaktören manipulerar därmed den mänskliga länken i säkerhetskedjan snarare än den tekniska infrastrukturen i sig.

Social engineering kan därmed kännetecknas av att den utnyttjar kommunikationskanaler och tekniska plattformar för att skapa trovärdiga scenarier [3, 12]. Kommunikationskanalerna och plattformarna fungerar här som möjliggörare: e-post, sociala medier och andra digitala system används för att distribuera budskap utformat som legitima meddelanden. Dessa meddelanden är dock färdigt konstruerade fällor, där tekniskt byggda url-länkar kan stjäla information eller leda till andra cyberhot. Attacken bygger samtidigt på psykologiska mekanismer såsom auktoritet, brådska eller tillit, vilket ökar sannolikheten för att offret agerar utan att ifrågasätta situationen.

Kombinationen av teknisk skicklighet och psykologisk påverkan gör social engineering till ett särskilt effektivt cyberhot. Även i tekniskt välskyddade miljöer kan en användare, genom manipulation, bli den punkt där säkerheten bryts [5]. Social engineering kan därmed fungera som en bro mellan mänskligt beteende och tekniskt intrång, vilket är orsaken till att den ofta utgör den initiala fasen i mer omfattande cyberattacker [3].

Vidare visar det sig att social engineering inte är en enskild metod för cyberattacker, utan en samling attackstrategier som kan anpassas av hotaktören enligt kontext och mål [8, 13]. Detta pekar på att hotet är genomtänkt och välstrukturerat istället för godtyckligt. Metodens flexibilitet, i kombination med beroende av både tekniska och psykologiska

faktorer, gör den svår att motverka genom allmänna skyddsåtgärder [12].

2.3 Psykologiska mekanismer bakom social engineering

Som tidigare nämnt bygger social engineering i grunden på psykologisk påverkan snarare än tekniskt utnyttjande. Angreppsmetodens effektivitet förklaras av dess utnyttjande av återkommande mönster i mänskligt beslutsfattande och social interaktion [4]. I stället för att kringgå tekniska säkerhetssystem påverkas individen direkt att själv utföra den handling som möjliggör intrånget.

Den underliggande mekanismen som ligger bakom social engineering är dess användning av kognitiva biaser, det vill säga systematiska tankefel som påverkar hur människor bedömer information och risk [4]. Som exempel kan auktoritetsbias leda till att en individ, utan närmare granskning, följer instruktioner från någon som uppfattas ha en chefsposition. På liknande sätt kan tidspress eller känslomässig påverkan minska benägenheten att ifrågasätta en viss situation.

Utöver individuella beslutsprocesser utnyttjar social engineering även sociala normer och organisatoriska strukturer [5]. Samarbetsvilja, tillit och respekt för hierarkier är nödvändiga för att organisationer ska fungera effektivt, men dessa faktorer kan samtidigt missbrukas av hotaktörer. Användningen av social engineering mot organisationer blir därmed möjlig eftersom de normer som tillåter fungerande arbetsmiljöer också skapar förutsättningar för manipulation.

Enligt översiktsstudier visar det sig att användare ofta underskattar sannolikheten att själva bli utsatta för manipulation [3]. Denna övertro på den egna förmågan att identifiera hot bidrar oftast till att enkla säkerhetsrutiner kringgås, även när medvetenhet om dessa risker existerar. Den psykologiska delen av social engineering riktar sig däremot inte enbart mot okunskap, utan även mot övertro och rutinmässigt beteende.

Enligt Europeiska unionens cybersäkerhetsbyrå (ENISA) påverkas mänskligt beteende i säkerhetskontext av både individuella och organisatoriska faktorer [6]. Arbetsbelastning, säkerhetskultur och tydlighet i rutiner spelar en stor roll för hur individer reagerar på potentiella hot. När dessa faktorer samverkar, leder det till att social engineering oftast lyckas och gör det svårt för individer att förstå att de har blivit utsatta för manipulation.

2.4 Angreppsmetoder och attacktyper

Social engineering omfattar en stor mängd olika angreppsmetoder som kan kategoriseras utifrån angreppssätt, kommunikationskanal eller tekniskt genomförande. För att tydliggöra hur manipulationen genomförs i praktiken har dessa angreppsmetoder strukturerats i

taxonomiska modeller [8, 13–15].

En av de mest allmänna attacktyperna är nätfiske, där hotaktören via e-post, meddelandetjänster eller webbplatser försöker lura mottagaren att lämna ut känslig information eller klicka på skadliga länkar [3, 12]. En mer riktad variant av nätfiske kallas för spjutfiske, där attacken anpassas efter en specifik individ eller organisation genom insamlad bakgrundsinformation [2]. Denna form av nätfiske anses ofta vara mer framgångsrik eftersom attacken upplevs som legitim och trovärdig.

Utöver e-postbaserade angrepp förekommer också pretexting som ett attackhot, där hotaktören skapar ett trovärdigt scenario eller berättelse för att manipulera offret att lämna ut känslig information [16]. Målgruppen för pretextingbaserade attacker är oftast organisatoriska roller, där hotaktören exempelvis låtsas vara IT-personal eller en överordnad chef. Andra vanliga attacktyper inkluderar också baiting, där offret manipuleras med lockande erbjudanden eller belöningar, och quid pro quo, där hotaktören erbjuder en tjänst i utbyte mot information [3, 12].

I sociala medier förekommer även attacker där förfalskade profiler används för att bygga upp förtroende över tid innan manipulationen genomförs [17]. Enligt den taxonomiska studien [14] kombinerar moderna social engineering-attacker ofta flera tekniker och kan integrera tekniska komponenter såsom domänförfalskning eller automatiserade meddelandesystem. Detta innebär att gränsen mellan tekniska och mänskliga angrepp blir alltmer otydlig.

2.4.1 Nätfiske och spjutfiske

Som tidigare nämnts bygger nätfiskeattacker på att hotaktörer utger sig för att representera en legitim organisation eller tjänst i syfte att lura mottagaren att lämna ut känslig information [3, 12, 15]. Information som hotaktörer oftast är ute efter kan inkludera inloggningsuppgifter, kreditkortsdata eller andra konfidentiella data.

Attackerna distribueras i de flesta fall via e-post, men förekommer även genom SMS (smishing), sociala medier och förfalskade webbplatser [3]. Den tekniska komponenten i nätfiskeattacker består ofta av e-postspoofing, manipulerade URL:er, domänförfalskning eller visuellt övertygande kopior av autentiska inloggningssidor [3, 10]. Attackens effektivitet uppstår genom att individer blir lurade av teknik och psykologisk påverkan för att uppfatta budskapet som äkta.

För att nätfiske ska lyckas krävs det en betydande mängd psykologisk manipulation. Enligt [4] utnyttjar hotaktörer ofta auktoritet, brådska och rädsla för att minska individers kritiska tänkande. Ett exempel är meddelanden som antyder att ett bankkonto äventyras, vilket skapar ett stressmoment som kan leda till impulsiva beslut.

Till skillnad från traditionella nätfiskeattacker, som massutskickar attacker oriktat,

riktar sig spjutfiske mot en specifik organisation eller individ [2]. Spjutfiske kan även anta formen av så kallad whaling, där högt uppsatta personer inom organisationer utgör målgruppen. Attacken bygger på insamlad bakgrundsinformation om offret, exempelvis genom öppna källor eller sociala nätverk. Den insamlade informationen möjliggör personligt anpassade meddelanden som ökar trovärdigheten och sannolikheten för en lyckad attack.

Moderna nätfiske- och spjutfiskeattacker integrerar allt fler tekniska och sociala komponenter [14]. Exempelvis kan hotaktörer kombinera en riktad informationsinsamling med artificiell intelligens (AI) för att generera språkligt sofistikerade meddelanden [10]. Forskning visar att användningen av AI i nätfiske- eller spjutfiskesammanhang har ökat attackernas trovärdighet och därmed försvårat åtskiljandet mellan legitim och bedräglig kommunikation [7].

2.4.2 Pretexting och identitetsbedrägeri

Till skillnad från nätfiske, där attacken ofta baseras på massdistribution, utgör pretexting en strukturerad och direkt form av social engineering. Hotaktören skapar ett trovärdigt scenario eller antar en falsk identitet i syfte att manipulera offret [7, 12, 15].

Grunden i pretexting är skapandet av ett sammanhang där hotaktören framstår som legitim. Beroende på målgruppen kan hotaktören exempelvis utge sig för att vara en arbetssökande, IT-personal eller en annan intern funktion inom en organisation [3]. Genom att utnyttja etablerade organisatoriska roller och hierarkier kan hotaktören minska sannolikheten för att manipulationen ifrågasätts.

Identitetsbedrägeri är nära kopplat till pretexting och innebär att hotaktörer aktivt imiterar en verklig person eller institution. Imitation kan exempelvis ske genom falska e-postadresser, manipulerade telefonnummer (caller ID spoofing) eller förfälskade profiler på sociala medier [13]. Även här kombineras tekniska verktyg med social manipulation för att skapa en övertygande illusion av autenticitet.

Enligt [5] utnyttjar pretextingbaserade attacker organisatoriska normer såsom samarbetsvilja, respekt för auktoritet och hjälpsamhet. Normerna är nödvändiga för att organisationer ska fungera effektivt, men de kan samtidigt utnyttjas av potentiella hotaktörer. Orsaken till att pretexting oftast ingår i bredare social engineering-attacker är att attacken inte enbart fokuserar på individers okunskap, utan också på strukturella och kulturella faktorer inom organisationer.

2.4.3 Insider-relaterade attacker

Insider-relaterade attacker skiljer sig från tidigare diskuterade attacker genom att de involverar individer som redan har tillgång till en organisations system från insidan [3]. Till skillnad från externa attacker bygger dessa hot, som sagt, på att en intern aktör, medvetet eller omedvetet, bidrar till attacken. Insiderhot kan delas in i två huvudkategorier: avsiktliga och oavsiktliga. Avsiktliga insiderattacker innebär att en anställd medvetet missbrukar sina åtkomsträttigheter, exempelvis för ekonomisk vinst eller sabotage [8, 14]. Oavsiktliga insiderincidenter uppstår däremot när en anställd manipuleras genom social engineering och därmed omedvetet möjliggör ett intrång.

Som redan nämnts utgör social engineering ofta en utgångspunkt för insiderrelaterade incidenter. Genom nätfiske, spjutfiske eller pretexting kan hotaktören påverka interna användare inom en organisation att kringgå säkerhetsrutiner eller ge obehörig åtkomst till system [3]. Forskning visar att bristande medvetenhet eller otydlig ansvarsfördelning kan skapa situationer där manipulation är mer framgångsrik. Därför spelar organisatoriska faktorer såsom säkerhetskultur, utbildningsnivå och tydliga rutiner en avgörande roll i hur mottaglig en organisation är för insider-relaterade attacker [6, 18].

Kapitel 3

Social engineering i praktiken

Detta kapitel behandlar social engineering ur ett praktiskt perspektiv. Inledningsvis diskuteras hur social engineering påverkar organisationer och infrastrukturer med hög säkerhetsnivå. Därefter presenteras relevanta fallstudier av social engineering-relaterade incidenter, där angreppsmetoder och konsekvenser analyseras i sitt sammanhang. Avslutningsvis behandlas de bredare konsekvenser som social engineering-attacker kan ha som följd för organisationer och samhällen.

3.1 Social engineering i samhällskritiska system

Social engineering utgör ett särskilt allvarligt hot när den riktas mot samhällskritiska system och infrastrukturer. Sådana system omfattar exempelvis energiförsörjning, finansiella tjänster, hälso- och sjukvård, telekommunikation och offentliga förvaltningar. Dessa samhällskritiska system kännetecknas av sin höga komplexitet, omfattande digitala sammankoppling och beroende av både tekniska och mänskliga processer [1, 5, 6].

För dessa system är tillgänglighet, integritet och konfidentialitet centrala säkerhetsprinciper. Social engineering påverkar dessa principer genom att manipulera den mänskliga komponenten istället för att direkt fokusera på infrastrukturens teknik. Enligt [3, 12] fungerar social engineering som en initial intrångsvektor, där användningen av olika angreppsmetoder möjliggör tekniska intrång i system och nätverk. För dessa system innebär detta exempelvis att en anställd avsiktligt eller oavsiktligt lämnar ut autentiseringsuppgifter, godkänner en obehörig åtkomstbegäran eller genomför en lösenordsåterställning.

För att motverka social engineering inom samhällskritiska system använder många organisationer avancerade tekniska skyddsåtgärder, såsom flerfaktoraутentisering (MFA), nätverkssegmentering och intrångsdetektionssystem. Oavsett dessa avancerade system fortsätter den mänskliga faktorn inom systemen att utgöra en betydande sårbarhet [5, 18]. Särskilt utsatta är operativa gränssnitt där mänskligt beslutsfattande kombineras med tek-

niska processer, såsom helpdesk-funktioner, administrativ åtkomsthantering och leverantörskommunikation. Som tidigare betonats av [5, 6] påverkar organisatoriska strukturer och arbetsprocesser hur motståndskraftiga dessa gränssnitt är mot manipulation.

3.2 Fallstudier av social engineering-relaterade incidenter

För att förtydliga hur social engineering framträder i praktiken analyseras i detta avsnitt utvalda verkliga incidenter. Fallstudierna syftar till att illustrera hur social engineering kan användas för både ekonomisk vinning och strategisk samhällspåverkan. Angreppsmetoder som tidigare presenterats kommer också att behandlas, där attackerna tillämpas i organisatoriska och politiska sammanhang. Fallstudierna kommer också att illustrera hur avancerade tekniska verktyg, som AI, kan förstärka manipulationens effektivitet.

3.2.1 Arup deepfake-bedrägeri

Under 2024 utsattes det internationella teknikkonsultföretaget Arup för en omfattande social engineering-attack där AI användes för att genomföra ett avancerat deepfake-bedrägeri [19, 20]. Händelsen lyfte fram hur AI i moderna social engineering-attacker kan förstärka traditionella manipulationsmetoder och skapa nya säkerhetsutmaningar för organisationer.

En anställd vid företagets kontor i Hongkong mottog ett meddelande som påstods komma från företagets ekonomichef (CFO). Kort därefter deltog den anställda i ett videomöte där flera personer som såg ut och lät som företagets chefer deltog. Enligt rapportering från både BBC och The Guardian var samtliga deltagare i videomötet AI-genererade deepfakes, där hotaktörerna hade manipulerat både bild och ljud för att imitera verkliga personer inom organisationen [19, 20]. Under mötet anvisades den anställda att genomföra ett antal banköverföringar till olika konton. Totalt överfördes cirka 20-25 miljoner amerikanska dollar genom flera separata transaktioner innan bedrägeriet upptäcktes [19, 20]. Arup bekräftade senare incidenten och att den utgjorde en form av teknologiskt förstärkt bedrägeri.

Ur ett cybersäkerhetsperspektiv visar Arup-fallet hur social engineering kan utvecklas genom integration av AI. Attacken byggde inte endast på utnyttjandet av tekniska sårbarheter i nätverk eller system, utan också på manipulation av en anställds förtroende i en situation som framstod som legitim [3]. Denna specifika incident överensstämmer med tidigare forskning från [3] där social engineering påstås fungera som en intrångsvektor, där hotaktören utnyttjar mänskligt beslutsfattande istället för tekniska brister.

Vidare hänvisar incidenten till utvecklingen av AI-stödd social engineering, där generativa modeller används för att producera språkligt och visuellt övertygande innehåll [7]. Genom att kombinera deepfake-teknologi med organisatorisk kontext skapade hotaktörerna ett trovärdigt scenario där traditionella tekniska säkerhetsåtgärder inte räckte till. Fallet bekräftar även [14] där det observeras att moderna social engineering-attacker ofta kombinerar tekniska och sociala komponenter i en integrerad angreppsstrategi. Deepfake-elementet utgjorde den tekniska komponenten, medan manipulationen av organisatoriska rutiner och beslutsprocesser utgjorde den sociala. Kombinationen möjliggjorde ett intrång utan att hotaktörerna behövde bryta igenom tekniska skyddssystem.

3.2.2 USA:s presidentval 2016

Förutom ekonomiskt motiverade attacker har social engineering också använts för politiska ändamål. Enligt [21] har flera demokratiska val blivit utsatta för koordinerade cyber- och desinformationsoperationer där teknik och psykologisk manipulation har kombinerats för att kontrollera informationsflödet. En av de mest dokumenterade exemplen på hur social engineering kan användas inom demokratiska val är USA:s presidentval 2016.

Under valrörelsen genomfördes riktade spjutfiske-attacker mot politiska kampanjorganisationer, som exempelvis Democratic National Committee (DNC). Genom nätfiske-attacker som utgav sig för att vara legitima säkerhetsvarningar lyckades hotaktörerna få tillgång till interna e-postkonton. Efter det lyckade intrånget började den stulna kommunikationen att publiceras via externa plattformar. Enligt [21] användes den stulna informationen strategiskt för att skapa uppmärksamhet på sociala medier och orsaka politisk polarisering och misstro. Syftet med attacken var därmed inte att manipulera rösträkningen rent tekniskt, utan att påverka det informationsmässiga och psykologiska klimatet kring valet. Enligt internationella utredningar kopplades attackerna i ett senare skede till statligt associerade ryska aktörer, vilket placerade incidenten i ett bredare geopolitiskt sammanhang [21].

Fallstudiet kan ses ur ett cybersäkerhetsperspektiv som en kombination av spjutfiske och desinformationsmanipulation. Angreppets initiala fas riktade sig mot enskilda individer genom social engineering, medan senare faser syftade till en samhällelig påverkan. Här blir kopplingen till en bredare definition av social engineering tydlig. Som tidigare nämnts beskriver [11] social engineering som ett försök att medvetet forma sociala strukturer och kollektiva beteenden genom strategisk påverkan. I fallet med USA:s presidentval 2016 riktades attacken inte mot enskilda individer, utan mot röstare och det demokratiska förtroendet som helhet. Här betonas samma princip av [21] att, även om den tekniska valinfrastrukturen inte nödvändigtvis manipulerades direkt, kunde desinformationsoperationerna påverka hur valet uppfattades.

3.3 Konsekvenser av social engineering-attacker

Som diskuterats ovan kan social engineering medföra konsekvenser som sträcker sig långt bortom från det initiala intrånget. Beroende på kontext kan effekterna vara ekonomiska, organisatoriska, politiska eller samhälleliga. Oberoende av motivationen bakom attacken har dessa alla gemensamt att de uppstår genom manipulation av mänskligt beslutsfattande snarare än direkt tekniskt utnyttjande.

Ur ett ekonomiskt perspektiv kan social engineering leda till allvarliga finansiella förluster. Arup-incidenten visar hur manipulation av en enskild anställd möjliggjorde överföring av miljontals amerikanska dollar utan att tekniska säkerhetssystem bröts [19, 20]. Liknande incidenter för med sig inte endast direkta ekonomiska förluster, utan även sekundära konsekvenser, såsom rättsliga utredningar, sanktioner och ökade säkerhetsinvesteringar. I organisatoriska sammanhang kan social engineering påverka förtroendet inom och mellan organisationer. När autentiseringsprocesser manipuleras, eller kommunikationskanaler utnyttjas, kan detta skapa osäkerhet kring rutiner och misstro mellan anställda. Enligt ENISA är säkerhetskultur och tydliga processer avgörande för att minska denna typ av organisatorisk sårbarhet [6]. Efter en incident kan organisationer tvingas att omvärdera sina säkerhetsstrategier och införa striktare kontroller, vilket kan leda till försämrad effektivitet och arbetsflöde.

På en samhällelig nivå kan konsekvenserna vara mer omfattande. USA:s presidentval 2016 illustrerar hur social engineering kan användas för att påverka informationsmiljöer och skapa skepticism [21]. Användningen av nätfiske och informationsmanipulering bidrog till ökad polarisering och misstro kring valet. Som incidenten klart visar, var målet med attacken inte att nå ekonomisk vinst, utan att påverka kollektiv perception och politiskt förtroende.

Från ett psykologiskt perspektiv påverkar social engineering-attacker också individers säkerhetsbeteende. Enligt [4] kan manipulationen genom brådska, auktoritet och stress leda till att individer underskattar risker eller agerar impulsivt. Efter en social engineering-incident kan individers säkerhetsbeteenden förändras på olika sätt. I vanliga fall leder händelsen till ökad vaksamhet, där användare blir mer försiktiga och uppmärksamma. I andra fall kan däremot upprepade varningar, säkerhetsförfrågningar och autentiseringsmeddelanden skapa så kallad säkerhetsutmattning [22]. Fenomenet innebär att individer, på grund av stress eller vana, börjar ignorera varningar eller godkänna förfrågningar utan noggrann observation.

Slutligen bidrar upprepade social engineering-incidenter även till en förskjutning i hotlandskapet. Enligt [3, 13, 14] utvecklas angreppsmetoder kontinuerligt genom tekniska verktyg och social manipulation. Detta innebär att konsekvenserna är reaktiva och att organisationer och samhällen måste konstant anpassa sig för att hantera cyberhotet.

Kapitel 4

Tekniska motåtgärder mot social engineering

Kapitlet kommer att analysera tekniska motåtgärder som kan användas för att förebygga, identifiera och begränsa social engineering-attacker. Som stöd används de angreppsmetoder och fallstudier som tidigare presenterats där en analys av hur tekniska säkerhetsåtgärder kan förstärka motståndskraften mot social manipulation. Inledningsvis diskuteras metoder för identifiering och detektion av social engineering-relaterade attacker. Därefter behandlas artificiell intelligens som en potentiell försvarsmekanism, med fokus på dess effektivitet och begränsningar. Avslutningsvis diskuteras autentisering och åtkomstkontroll som tyngdpunkt i skyddet mot obehörig åtkomst och identitetsbedrägeri.

4.1 Identifiering och detektion av social engineering-attacker

Eftersom social engineering riktar sig mot mänskligt beslutsfattande kan identifiering av dessa attacker vara särskilt svår. Till skillnad från traditionella intrång, där skadlig kod eller nätverksintrång kan upptäckas genom teknisk övervakning, sker social manipulation ofta genom kommunikationskanaler som e-post, short message service (sms) eller sociala medier [3, 12]. Av denna anledning fokuserar en stor del av detektionsarbetet på tekniska filtrerings- och analysmekanismer. I nätfiskedetektion används exempelvis e-postfiltrering samt analys av URL-strukturer, domänvalidering och maskininlärningsbaserade klassificeringsmodeller för att identifiera suspekta meddelanden innan de når offret [10]. Systemen kan exempelvis analysera avsändarinformation, språkmönster och beteendeavvikelser för att markera potentiellt skadligt innehåll.

Utöver de ovannämnda detektionssystemen används ofta säkerhetsinformation och händelsehantering (SIEM)-system för att samla in och korrelera säkerhetsloggar från olika delar av en organisations infrastruktur. Genom kombinationen av SIEM och intrångs-

detekteringssystem (IDS) kan misstänkt aktivitet identifieras i realtid. Enligt [23] visar integrationen av SIEM och IDS med maskininlärningsmodeller en förbättrad förmåga att upptäcka ovanliga inloggningsförsök eller typiska åtkomstförsök. Moderna organisationer har även börjat implementera Security Orchestration, Automation and Response (SOAR)-system. Ett SOAR-system integrerar flera olika säkerhetsverktyg i en gemensam miljö som möjliggör automatiserad hantering av säkerhetsincidenter [24]. Genom insamlade data från exempelvis SIEM-system, e-postfilter och hotinformationsdatabaser kan SOAR automatiskt initiera åtgärder såsom blockering av konton, isolering av enheter eller återkallande av skadliga länkar. Därmed möjliggör SOAR snabbare identifiering och respons vid social engineering-relaterade incidenter.

Trots alla dessa system kvarstår utmaningar. Eftersom social engineering bygger på psykologi snarare än teknik, kan välkonstruerade attacker fortfarande undvika traditionella säkerhetsfilter [3]. Därför betonas i organisatoriska sammanhang vikten av att kombinera tekniska detektionssystem med organisatoriska rutiner och användarmedvetenhet för att uppnå optimalt skydd.

4.2 Artificiell intelligens som försvarsmekanism

Utvecklingen av AI har dragit med sig både för- och nackdelar inom cybersäkerhet. I dagens cyberhotlandskap har AI sett en ökad användning av hotaktörer för att exempelvis skapa mer övertygande nätfiskeattacker eller djupfejkmaterial, medan samma teknologi har blivit ett centralt verktyg för att motverka dessa social engineering-attacker [7].

Orsaken till att AI har blivit ett viktigt verktyg för att motverka social engineering-attacker är dess förmåga att analysera stora mängder data och identifiera mönster som kan vara svåra att upptäcka manuellt. I nätfiskedetektion används exempelvis maskininlärningsmodeller för att enkelt markera e-postmeddelanden baserat på språk, metadata, URL-strukturer och avsändarbeteende [10]. Genom att kontinuerligt träna modellerna med nya data kan försvaret mot social engineering upprätthållas i realtid. Enligt [25] kan AI även användas för att förstärka användarstöd och beslutsfattande. Genom specialiserade varningssystem och kontextbaserade säkerhetsindikatorer kan AI minska risken för impulsivt agerande vid en social engineering-attack.

Som redan nämnt fungerar AI inte endast som en universallösning. Eftersom hotaktörer också använder AI för att skapa mer sofistikerade angrepp, uppstår det en form av kapprustning [7]. För att hållas i kapp måste därför försvarssystem kontinuerligt uppdateras och kombineras med organisatoriska säkerhetsrutiner [14].

4.2.1 Användningen av maskininlärning för detektion

Som nämnts ovan utgör maskininlärning (ML) en central del av AI-baserade försvarssystem mot social engineering. Till skillnad från traditionella försvarssystem, som kräver fördefinierade kriterier, kan användningen av övervakad och oövervakad maskininlärning användas för att identifiera komplexa mönster även i stora datamängder [10]. Användningen av metoderna möjliggör anpassning till kontinuerligt förändrande attacker.

I nätfiske-relaterad detektion används ofta övervakad inlärning, där modeller tränas på specifika dataset bestående av skadliga och ofarliga meddelanden. Genom att fokusera på exempelvis analys av språkliga strukturer, avsändardomäner, metadata och förekomsten av språkliga indikatorer på brådska, såsom tidsbegränsningar, krav på omedelbar åtgärd eller hot om negativa konsekvenser, kan modellen klassificera nya meddelanden med större sannolikhet [10]. Metoden möjliggör konstant förbättring av detektionsprecisionen i takt med nya data. Utöver övervakad inlärning används också oövervakad inlärning för att identifiera avvikande beteendemönster. I dessa fall analyseras en användares aktivitetsmönster, som exempelvis inloggningstider och geografisk placering. Om användarens beteende avviker i stor grad från det normala kan systemet generera en varning om ett potentiellt äventyrande konto [23]. Metoden är därför särskilt användbar i situationer där hotaktören redan har fått åtkomst till autentiseringsuppgifter genom lyckad social engineering.

ML används även i kombination med SIEM- och IDS-system för att möjliggöra realtidsanalys av nätverkstrafik och autentiseringsloggar [23]. Genom att använda flera datakällor kan systemet skapa en helhetsbild av det potentiella hotet. Integrationen möjliggör förbättrad identifiering av komplexa attacker som kombinerar tekniskt utnyttjande med social manipulation. Oavsett sina styrkor har ML också begränsningar. Modellerna är mycket beroende av kvaliteten på träningsdata och kan vara särskilt känsliga för så kallade fientliga attacker, där hotaktörer medvetet manipulerar inputdata för att undvika detektion [14]. ML bör därför förstås som en del av en helhetsstrategi istället för en självständig lösning.

4.2.2 Begränsningar och risker med AI

Även om AI erbjuder avancerade möjligheter för detektion och respons med hjälp av ML, är teknologin ingen universallösning mot social engineering. Eftersom ML är grunden för AI påverkas AI indirekt av samma brister som ML drabbas av. AI-baserade system är därmed beroende av inlärningsdata, modellarkitektur och uppdateringar. Om träningsdata är bristfälliga eller utsätts för en fientlig attack, kan modellen utveckla brister i sin klassificeringsförmåga [10, 14]. Därtill kvarstår det centrala problemet med AI, vilket är att

hotaktörerna också använder sig av AI. Användningen av AI skapar då indirekt en osynlig teknologisk kapprustning där både angripare och försvarare använder sig av samma verktyg för att ligga steget före den andra [7].

Dessutom förekommer det fler begränsningar med AI i form av dess analyseringsprocesser. AI analyserar tekniska indikatorer, medan social engineering i grunden är ett socio-tekniskt fenomen [5]. Manipulationer sker i mänskliga sammanhang, organisatoriska rutiner och beslutsprocesser, där även de mest avancerade AI-systemen inte fullt kan ersätta mänskligt beslutsfattande eller säkerhetskultur. Därpå kan nya risker uppstå i organisationer på grund av ett överdrivet beroende av AI. Överdrivet beroende kan leda till utvecklingen av falsk trygghet och förlitande på AI-baserat skydd, vilket därmed kan leda till minskad vaksamhet eller riskbedömning.

4.3 Autentisering och åtkomstkontroll

Eftersom social engineering är en kombination av både psykologisk manipulation och användning av tekniska verktyg, krävs det mer avancerade lösningar för att uppnå optimalt skydd. Tekniska system, som AI-baserat skydd, kan identifiera och blockera många sorters angrepp, men den mänskliga faktorn kvarstår i beslutsprocesser och beteendemönster. Specifikt för organisationer spelar säkerhetskultur, utbildningsnivå och interna rutiner en avgörande roll i hur motståndskraftiga de är mot social engineering [5]. Trots de olika motåtgärderna är utbildnings- och medvetandeprogram bland de mest använda. Enligt [22] är dessa utbildningsprogram däremot bristfälliga, eftersom utbildningen ofta erbjuds endast några gånger istället för kontinuerligt. För att uppnå ett effektivt skydd bör utbildningen vara återkommande, scenariobaserad och anpassad efter organisationens behov.

ENISA betonar betydelsen av att utveckla en stark cybersäkerhetskultur där säkerhetsbeteenden integreras i vardagliga rutiner [6]. Integrationen av cybersäkerhetskultur innebär att säkerheten inte endast ska fungera som en teknisk funktion utan även som en del av organisationen och dess ledarskap. När dessa säkerhetsprinciper tydligt är anpassade till organisationens struktur minskar sannolikheten för lyckad manipulation. Ett exempel på detta är användningen av simulerade nätfiskekampanjer för att mäta och förbättra arbetarnas motståndskraft [18]. Genom kontrollerade tester kan organisationer identifiera sårbarheter och anpassa utbildningsinsatser i efterhand. Samtidigt måste även dessa simuleringar genomföras med hänsyn till organisatorisk tillit och arbetsmiljö, eftersom övervakning kan påverka arbetarnas upplevelse och trygghet.

Utöver olika utbildningar är tydliga policyer och rutiner viktiga för säkerheten [8]. Principer som lägsta behörighet, tydliga verifieringsprocesser vid ekonomiska transaktioner och användning av flerfaktorautentisering bidrar också till förbättrat skydd [14].

Genom att implementera dessa strukturella säkerhetsåtgärder kan organisationer begränsa skadan även om en individ blir utsatt för manipulation.

Kapitel 5

Diskussion

Kapitel 6

Slutsats

Källförteckning

- [1] Noah Hellund. ”Cybersäkerhet i finländska kommuner: Kommuners kunskapsnivå och beredskap inom området cybersäkerhet”. Magisters avhandling. Åbo Akademi, 17 jan. 2026. URL: <https://www.doria.fi/handle/10024/192769>.
- [2] C. S. Bhusal. ”Systematic Review on Social Engineering: Hacking by Manipulating Humans”. I: *Journal of Cyber Security Technology* 12.1 (15 febr. 2026), s. 104–114. DOI: [10.4236/jis.2021.121005](https://doi.org/10.4236/jis.2021.121005). URL: <https://www.scirp.org/journal/paperinformation?paperid=106599>.
- [3] Fatima Salahdine och Naima Kaabouch. ”Social Engineering Attacks: A Survey”. I: *Future Internet* 11.4 (20 febr. 2026). DOI: [10.3390/fi11040089](https://doi.org/10.3390/fi11040089). URL: <https://www.mdpi.com/1999-5903/11/4/89>.
- [4] M. A. Siddiqy m.fl. ”A Study on the Psychology of Social Engineering-Based Cyberattacks and Existing Countermeasures”. I: *Applied Sciences* 12.12 (15 febr. 2026). DOI: [10.3390/app12126042](https://doi.org/10.3390/app12126042). URL: <https://www.mdpi.com/2076-3417/12/12/6042>.
- [5] A. H. Washo. ”An interdisciplinary view of social engineering: A call to action for research”. I: *Computers in Human Behavior Reports* 4 (15 febr. 2026). DOI: [10.1016/j.chbr.2021.100126](https://doi.org/10.1016/j.chbr.2021.100126). URL: <https://www.sciencedirect.com/science/article/pii/S2451958821000749>.
- [6] The European Union Agency for Network and Information Security (ENISA). *Cybersecurity Culture Guidelines: Behavioural Aspects of Cybersecurity*. ENISA, 20 febr. 2026. DOI: [10.2824/324042](https://doi.org/10.2824/324042). URL: <https://www.enisa.europa.eu/sites/default/files/publications/WP2018%200.3.3.2.%20Review%20of%20Behavioural%20Sciences%20Research%20in%20the%20Field%20of%20Cybersecurity.pdf>.
- [7] Marc Schmitt och Ivan Flechais. ”Digital deception: generative artificial intelligence in social engineering and phishing”. I: *Artificial Intelligence Review* 57.324 (15 febr. 2026). DOI: [10.1007/s10462-024-10973-2](https://doi.org/10.1007/s10462-024-10973-2). URL: <https://link.springer.com/article/10.1007/s10462-024-10973-2>.

- [8] H. Gururaj m. fl. *Social Engineering in Cybersecurity: Threats and Defenses*. CRC Press, 2024. DOI: [10.1201/9781003406716](https://doi.org/10.1201/9781003406716). URL: <https://www.taylorfrancis.com/books/edit/10.1201/9781003406716/social-engineering-cybersecurity-gururaj-janhavi-ambika>.
- [9] Zuoguang Wang m. fl. "Social engineering in cybersecurity: a domain ontology and knowledge graph application examples". I: *Cybersecurity* 4 (17 jan. 2026), Artikel 31. DOI: [10.1186/s42400-021-00094-6](https://doi.org/10.1186/s42400-021-00094-6). URL: <https://cybersecurity.springeropen.com/articles/10.1186/s42400-021-00094-6>.
- [10] Gaurav Varshney m. fl. "Anti-phishing: A comprehensive perspective". I: *Expert Systems with Applications* 238 (20 febr. 2026). DOI: [10.1016/j.eswa.2023.122199](https://doi.org/10.1016/j.eswa.2023.122199). URL: <https://doi.org/10.1016/j.eswa.2023.122199>.
- [11] Adam Podgórecki, John Alexander och Rob Shields. *Social Engineering*. Available from: ProQuest Ebook Central. [3 mars 2026]. Montreal: McGill-Queen's University Press, 1996.
- [12] I. A. M. Abbas. "Social Engineering Threat and Defense: A Literature Survey". I: *Journal of Information Security* 9.4 (15 febr. 2026), s. 257–264. DOI: [10.4236/jis.2018.94018](https://doi.org/10.4236/jis.2018.94018). URL: <https://www.scirp.org/journal/paperinformation?paperid=87360>.
- [13] Arianit Maraj och William Butler. "Taxonomy of Social Engineering Attacks: A Survey of Trends and Future Directions". I: *International Conference on Cyber Warfare and Security (ICCWS)* 17.1 (15 febr. 2026). DOI: [10.34190/iccws.17.1.40](https://doi.org/10.34190/iccws.17.1.40). URL: <https://papers.academic-conferences.org/index.php/iccws/article/view/40>.
- [14] Mohamed Zaoui m. fl. "A Comprehensive Taxonomy of Social Engineering Attacks and Defense Mechanisms: Toward Effective Mitigation Strategies". I: *IEEE Access* 12 (20 febr. 2026), s. 72224–72241. DOI: [10.1109/ACCESS.2024.3403197](https://doi.org/10.1109/ACCESS.2024.3403197). URL: <https://ieeexplore.ieee.org/document/10535157>.
- [15] S.A.D.T.P Kaushlya m. fl. "An Overview of Social Engineering in the Context of Information Security". I: *2018 IEEE 5th International Conference on Engineering Technologies and Applied Sciences (ICETAS)* (15 febr. 2026), s. 1–6. DOI: [10.1109/ICETAS.2018.8629126](https://doi.org/10.1109/ICETAS.2018.8629126). URL: <https://ieeexplore.ieee.org/document/8629126>.
- [16] António Lopes m. fl. "Common Techniques, Success Attack Factors and Obstacles to Social Engineering: A Systematic Literature Review". I: *Emerging Science Journal* 8.2 (15 febr. 2026). DOI: [10.28991/ESJ-2024-08-02-025](https://doi.org/10.28991/ESJ-2024-08-02-025). URL: <https://www.ijournalse.org/index.php/ESJ/article/view/2194>.

- [17] Kaouthar Chetoui m. fl. "Overview of Social Engineering Attacks on Social Networks". I: *Procedia Computer Science* 198 (20 febr. 2026). DOI: [10.1016/j.procs.2021.12.302](https://doi.org/10.1016/j.procs.2021.12.302). URL: <https://doi.org/10.1016/j.procs.2021.12.302>.
- [18] Dalal N. Alharthi och Amelia C. Regan. "Social Engineering Defense Mechanisms: A Taxonomy and a Survey of Employees' Awareness Level". I: *Intelligent Computing* 1228 (20 febr. 2026), s. 521–541. DOI: [10.1007/978-3-030-52249-0_35](https://doi.org/10.1007/978-3-030-52249-0_35). URL: https://doi.org/10.1007/978-3-030-52249-0_35.
- [19] The Guardian. *UK engineering firm Arup falls victim to £20m deepfake scam*. Hämtad [14 mars 2026]. 17 maj 2024. URL: <https://www.theguardian.com/technology/article/2024/may/17/uk-engineering-arup-deepfake-scam-hong-kong-ai-video>.
- [20] BBC News. *Deepfake attack: 'Many people could have been cheated'*. Hämtad [14 mars 2026]. 2 mars 2026. URL: <https://www.bbc.com/news/articles/c0j59vydxj9o>.
- [21] Aaltola, Mika and Mattisen, Mariita. *Election Hacking in Democracies: The example of the U.S. 2016 elections*. Finnish Institute of International Affairs, 17 mars 2026. URL: <https://fiia.fi/en/publication/election-hacking-in-democracies>.
- [22] Hussain Aldawood och Geoffrey Skinner. "Reviewing Cyber Security Social Engineering Training and Awareness Programs—Pitfalls and Ongoing Issues". I: *Future Internet* 11.3 (20 febr. 2026). DOI: [10.3390/fi11030073](https://doi.org/10.3390/fi11030073). URL: <https://www.mdpi.com/1999-5903/11/3/73>.
- [23] A. R. Muhammad m. fl. "Integrated Security Information and Event Management (SIEM) with Intrusion Detection System (IDS) for Live Analysis based on Machine Learning". I: *Procedia Computer Science* 217 (17 mars 2026), s. 1406–1415. DOI: [10.1016/j.procs.2022.12.339](https://doi.org/10.1016/j.procs.2022.12.339). URL: <https://doi.org/10.1016/j.procs.2022.12.339>.
- [24] Sandro Waelchli och Yoshija Walter. "Reducing the risk of social engineering attacks using SOAR measures in a real world environment: A case study". I: *Computers & Security* 148 (15 febr. 2026). DOI: [10.1016/j.cose.2024.104137](https://doi.org/10.1016/j.cose.2024.104137). URL: <https://www.sciencedirect.com/science/article/pii/S0167404824004425>.
- [25] Ben Eriksson. "Artificiell intelligens för att motverka social manipulation". Magisters avhandling. Åbo Akademi, 17 jan. 2026. URL: <https://www.doria.fi/handle/10024/189260>.